Berner Fachhochschule
Haute école spécialisée bernoise
Bern University of Applied Sciences



IAM

Qualitätsmodelle

Prof. Dr. Annett Laube, HS 2026, HSLU

Qualitätsmodell

Ausgehend von einer Risiko-Analyse (Risk-Assessment) der **Anwendung (RP)** wird der Bedarf an die Qualität der verwendeten Identität und deren Attribute bestimmt

1. Qualität der Authentifizierung
2. Qualität der Attribute

Qualität der Authentifizierung

- Überblick
  - Vertrauensstufen der Authentifizierung (VSA)
  - Vertrauensstufen der Registrierung (VSR)
  - Vertrauensstufen der Steuerung (VSS)
  - Vertrauensstufen der Föderierung (VSF)

Qualität der Authentifizierung

- Die **Qualität der Authentifizierung** eines Subjektes wird – zum einfacheren Verständnis – in (meist 3 oder 4) **Vertrauensstufen** eingeteilt.
  - Synonyme: Vertrauensniveau, Sicherheitsniveau, level of assurance (LoA)
  - **Kein** Synonym ist «Level of Authentication» (LoA)

- Die Qualität macht eine Aussage darüber, wie sicher ein nutzender Dienst (RP) sein kann, dass das Subjekt wirklich die Identität besitzt, die es vorgibt zu haben.

- Dazu werden verschiedene Kriterien der Definitionszeit (Registrierung/Identifizierung), der Laufzeit (Authentisierung), der IAM-Topologie und auch organisatorisch/rechtliche Regelungen in einbezogen.

Authentication Assurance Standards



- NIST Digital Identity Guidelines: https://pages.nist.gov/800-63-4/ -
  - Richtlinien für die Implementierung digitaler Authentifizierungssysteme in staatlichen Behörden der USA



- ISO/IEC 29115 Entity Authentication Assurance Framework (2020): http://www.iso.org/iso/iso_catalogue/catalogue_tc/catalogue_detail.htm?csnumber=45138
  - Der Standard beschreibt 4 „levels of entity authentication assurance“, oder kurz LoA.
  - Grundlage für die eIDAS Verordnung

Authentication Assurance Standards



- EU Regulation 910/2014:

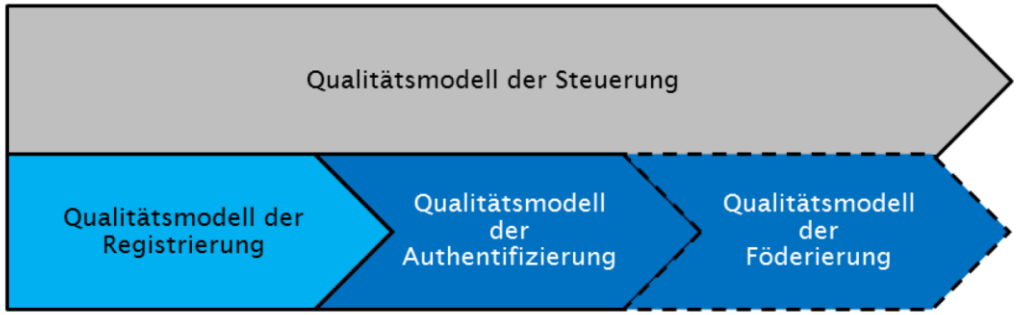
  Implementing Regulation of the EU 2015/1502:

  - Ziel: grenzübergreifendes, föderiertes Identitätssystem unter den Mitgliedstaaten
  - für die Schweiz nicht bindend, aber für die Akzeptanz von schweizerischen elektronischen Identitäten (E-ID) fundamental.
  - Anpassungen 2024: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex%3A32024R1183

eCH-0170v2 - Qualitätsmodell zur Authentifizierung von Subjekten:

- basiert auf 3 europäischen bzw. internationalen Standards
- Geeignet föderierte und nicht föderierte IAM-Systeme

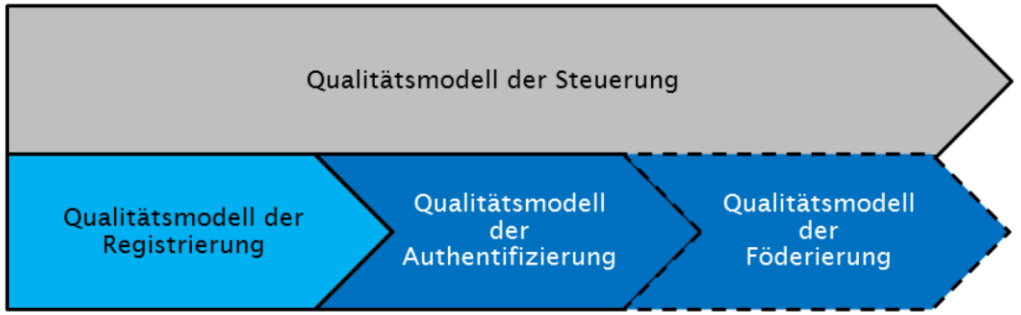
Teilmodelle nach eCH-0170 v2



- ***Qualitätsmodell der Authentifizierung***: Definiert die Vertrauensstufen der Authentifizierung (**VSA**) basierend auf der **Stärke** und möglichen Zertifizierungen eines **Authentifizierungsmittels**.

- ***Qualitätsmodell der Registrierung***: Definiert die Vertrauensstufen der Registrierung (**VSR**), dabei wird zwischen natürlichen und juristischen Personen unterschieden.
  - Die Qualität der Registrierung natürlicher Personen wird durch die **Stärke der Identifikation** der Person sowie der **Übergabe und Verlängerung der Authentifizierungsmittel** bestimmt.
  - Die Registrierung juristischer Personen wird durch die Stärke der Registrierung der zugehörigen natürlichen Person, der Identifizierung der juristischen Person sowie der **Verknüpfung** der beiden Personen bestimmt.

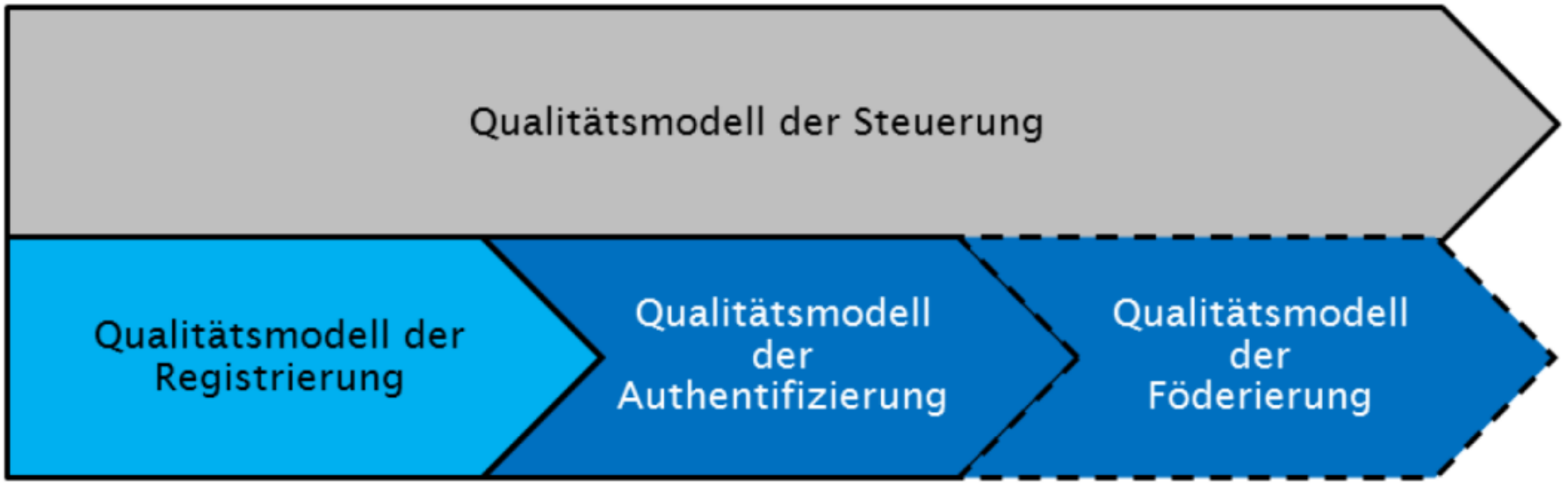
Teilmodelle nach eCH-0170 v2



- ***Qualitätsmodell der Steuerung***: Definiert die Vertrauensstufen der Steuerung (VSS) basierend auf den Kriterien **Aufsicht, Haftung und Maturität**.

- ***Qualitätsmodell der Föderierung***: Definiert die Vertrauensstufen der Föderierung (VSF) basierend auf der Authentizität, dem Vertraulichkeitsschutz, der Übermittlungsform und dem Nachweis des Besitzes der **Authentifizierungsbestätigung**.

Teilmodelle



- Die Teilmodelle werden je nach Art des IAM-Systems komponiert oder können auch einzeln für die Einstufung der IAM-Akteure verwendet werden
  - So kann z.B. das Qualitätsmodell der Registrierung zur qualitativen Bewertung einer RA verwendet werden.

Bestimmung der Stufen

- Jede Stufe besteht aus mehreren Kriterien
  - Das niedrigste Kriterium bestimmt die Stufe.
  - Die Kriterien können durch weitere ergänzt werden.

- Die niedrigste Stufe eines Teilmodells bestimmt die Stufe des Gesamtmodells.

Vertrauens-stufe	Bezeichnung	VSA	VSR VSRN/VSRJ	VSS	VSF
1	Kein oder minimales Vertrauen	**1**	**1**	**1**	1
2	Geringes Vertrauen	**2**	**2**	**2**	2
3	Beträchtlich-es Vertrauen	**3**	**3**	**3**	2
4	Hohes Ver-trauen	**4**	**4**	**4**	3

Qualität der Authentifizierung

- Überblick
  - Vertrauensstufen der Authentifizierung (VSA)
  - Vertrauensstufen der Registrierung (VSR)
  - Vertrauensstufen der Steuerung (VSS)
  - Vertrauensstufen der Föderierung (VSF)

Vertrauensstufen der Authentifizierung (VSA)

Vertrau-ensstufe der Authentifizier-ung (VSA)	Authentifizierungsmittel		Zertifizierung Auth.mittel	Re-Authentifizierung
	Reguläre Au-thentifizierung	Einmalige Authentifi-zierung nach Online-Identifikation		
1	SFA	IDN1	keine	ReAuth1
2	MFA	IDN2	keine	ReAuth2
3	HW-MFA	IDN3	keine	ReAuth3
4	HW-MFA	IDN4	Zertifizierung	ReAuth4

VSA: Kriterium Authentifizierungsmittel

- **Fragen:**
  - Kann das Authentifizierungsmittel nur unter der Kontrolle oder im Besitz des Subjektes, dem es gehört, verwendet werden?
  - Bietet das Authentifizierungsmittel Schutz vor Duplizierung und Fälschung durch Dritte?
  - Ist das Authentifizierungsmittel so gestaltet, dass es vom Subjekt zuverlässig vor einer Benutzung durch andere geschützt werden kann?

- **2 Möglichkeiten:**
  - Reguläre Authentifizierung
  - Einmalige Authentifizierung nach Online-Identifikation
    - Abhängig von der Identifikation des Benutzers (entspricht somit der Vertrauensstufe der Registrierung - VSR).

VSA: Kriterium Authentifizierungsmittel

3 Ausprägungen:

- **Single-Factor Authentication (SFA)**
  - Memorized Secret (z.B. Passwort, PIN), Look-Up Secret (z.B. Strichliste), Out of Band Authenticator (z.B. Bestätigung über SMS)
- **Multi-Factor Authentication (MFA)**
  a) Multi-Factor Authenticator, wie z.B. Multi-Factor OTP Software Authenticator
  b) Kombination von 2 verschiedenen Single-Factor-Authentifizierungsmittel, mit unterschiedlichen Authentifizierungsfaktoren
- **Hardware based Multi-Factor Authentication (HW-MFA)**
  - Multi-Factor OTP Device (Authenticator App), Multi-Factor Cryptographic Device (Smartcard)

VSA: Kriterium Zertifizierung des Authentifizierungsmittel

- **Fragen**:
  - Ist das Authentifizierungsmittel zertifiziert?
  - Bietet das Authentifizierungsmittel bestmöglichen Schutz vor Angriffen?

- **Ausprägung**:
  - Keine Zertifizierung
  - Zertifizierung nach FIPS 140-2 Level 3 bzw. Common Criteria EAL 4+
    - **Level 1:** Grundlegende Sicherheitsanforderungen
    - **Level 2:** Manipulationsschutz und Rollen-/Benutzerauthentifizierung.
    - **Level 3:** Verstärkter physischer Schutz; Manipulationsversuche sollen erkannt bzw. verhindert werden.
    - **Level 4:** Höchste Sicherheitsstufe; umfassender Schutz gegen physische.

VSA: Kriterium Re-Authentifizierung

- **Fragen**:
  - Nach welcher Zeitdauer muss eine RP - unabhängig von ihrem eigenen Session Management - ein Subjekt erneut vom IdP authentifizieren lassen?
  - Wie kann bei einer laufenden Sitzung sichergestellt werden, dass das Subjekt immer noch dasselbe ist, wie bei der initialen Authentifizierung durch den IdP?
- **Ausprägungen:**
  - **ReAuth1**: nach einer adäquaten Zeitspanne (z.B. 30 Tage)
  - **ReAuth2**: nach max. **18 h** erneut Authentifizierung durch den IdP, unabhängig von der Nutzungsaktivität. Ein Authentifizierungsfaktor ist ausreichend.
  - **ReAuth3**: nach max. **12 h**. **Alle** Authentifizierungsfaktoren müssen berücksichtigt werden.
  - **ReAuth4**: nach max. **30 min**. **Alle** Authentifizierungsfaktoren müssen in der **genau der gleichen** Art und Weise angewendet werden, wie initial.

Qualität der Authentifizierung

- Überblick
  - Vertrauensstufen der Authentifizierung (VSA)
  - Vertrauensstufen der Registrierung (VSR)
  - Vertrauensstufen der Steuerung (VSS)
  - Vertrauensstufen der Föderierung (VSF)

Vertrauensstufen der Registrierung (VSR)

- Nur natürliche Personen

Vertrauensstufen der Registrierung (VSRN) für natürl. Personen	Identifikation natürl. Personen	Übergabe Auth.mittel[9]	Verlängerung Auth.mittel
1	IDN1	1	CN1
2	IDN2	2	CN2
3	IDN3	3	CN3
4	IDN4	4a oder 4b	CN4

VSR – Kriterium Identifikation natürlicher Personen

- **Fragen**:
  - Wie wurde die Identität einer natürlichen Person, welcher eine Identität ausgestellt wurde, überprüft?
  - Nach welchen Gesichtspunkten wurden optionale Attribute verifiziert?

- Das Kriterium setzt sich aus 4 Faktoren zusammen
  - Faktor Anwesenheit
  - Faktor Beweismittel
  - Faktor Validierung der Angaben
  - Faktor Nichtabstreitbarkeit

VSR – Identifikation - Anwesenheit

- **Fragen:**
  - In welcher Form ist der Antragsteller bei der Identifikation anwesend?
  - Kann festgestellt werden, dass die natürliche Person existiert und persönlich anwesend ist?

- **Ausprägungen:**
  - **PP.a**: Keine Anwesenheit
  - **PP.b**: Online (über Netzwerk, z.B. Internet, Telefon, anwesend)
  - **PP.c**: Virtual in Person (PP.b) und audiovisuelle Kommunikation in Echtzeit
  - **PP.d**: In Person (physisch)

VSR – Identifikation - Beweismittel

- **Fragen:**
  - Ist das Beweismittel echt und gültig?
  - Stammt das Beweismittel aus einer verlässlichen und anerkannten Quelle?
- **Ausprägungen:**
  - **IE.a**: Kein Beweismittel, oder nicht aussagekräftig
  - **IE.b**: Beweismittel vorhanden: enthält Identifikator und Sicherheitsmerkmale
  - **IE.c**: Beweismittel anerkannt und geprüft: IE.b und
    - Beweismittel im Kontext anerkannt und auf Echtheit geprüft,
    - Gültiges Identitätsdokument
    - Elektronischer Nachweis einer gleich- oder höherwertigen Identität (E-ID)
  - **IE.d**: Beweismittel für körperliche Merkmale: IE.c und staatlich anerkanntes Beweismittel mit körperlichen Merkmalen der Person wird geprüft.

VSR – Identifikation – Validierung der Angaben

- **Fragen:**
  - Kann die Verbindung zwischen dem Antragsteller (Subjekt), der die Beweismittel präsentiert, und der behaupteten Identität des Subjekts hergestellt werden?
  - Stimmen die vom Antragsteller gemachten Angaben mit den Daten der vorgelegten Beweismittel überein?
- **Ausprägungen:**
  - **IV.a**: Keine Validierung
  - **IV.b**: Adäquate Validierung: Antragsteller ist im Besitz des Beweismittels, Angaben werden mit Beweismittel geprüft
  - **IV.c**: Starke Validierung: IV.b und genauere Prüfung von Beweismittel und Angaben
  - **IV.d**: Höchste Validierung: IV.c und Abgleich mit biometrischen Merkmalen und Überprüfung Postadresse

VSR – Identifikation – Nichtabstreitbarkeit

- **Fragen:**
  - Kann zu einem späteren Zeitpunkt (nach der Validierung der Identität) bewiesen werden, dass ein Antragsteller bei der Registrierung anwesend war?
  - Kann verhindert werden, dass das Subjekt die Anwesenheit bei der Registrierung (und damit die Ausstellung eines Authentifizierungsmittels) abstreitet?

- **Ausprägungen:**
  - **NP.a**: Keine Erhebung von Daten
  - **NP.b**: Kopie Identitätsdokument: Zum Zeitpunkt der Überprüfung wird eine Kopie eines Beweismittels, das körperliche Merkmale enthält, erstellt und abgelegt.
  - **NP.c**: Erhebung biometrische Daten: zum Zeitpunkt der Überprüfung der Identität werden biometrische Daten (z.B. Fingerabdrücke oder Gesichtsbilder) erhoben und gespeichert, um die Präsenz des Antragsstellers zu dokumentieren.

VSR – Kriterium Identifikation natürlicher Personen

Ausprä-gungen	Beschreibung	Anwe-senheit	Beweis-mittel	Validie-rung der Angaben	Nichtab-streitbar-keit
IDN1	Alle Informationen zur Identität sind selbstdeklariert und nicht überprüft.	PP.a	IE.a	IV.a	NP.a
IDN2	Die Informationen zur Identität werden mit Hilfe anscheinend echter und gültiger Beweismit-tel überprüft. Der Antragsteller kann phy-sisch oder online anwesend sein.	PP.b, PP.c oder PP.d	IE.b	IV.b	NP.a

VSR – Kriterium Identifikation natürlicher Personen

Ausprä-gungen	Beschreibung	Anwe-senheit	Beweis-mittel	Validie-rung der Angaben	Nichtab-streitbar-keit
IDN3	Zusätzlich zur Stufe IDN2: Die Beweismittel wurden stark validiert. Zum Zeitpunkt der Überprü-fung wurde die Kopie eines Beweismittels mit körperlichen Merkmalen erstellt.	PP.b, PP.c oder PP.d	1x IE.c oder 2 x IE.b	IV.c	NP.b
IDN4	Zusätzlich zur Stufe IDN3: Der Antragsteller muss phy-sisch oder „virtual in-person“ anwesend sein. Die biometrischen Angaben aus dem Beweismittel werden überprüft. Zum Zeitpunkt der Überprü-fung wurde die Präsenz des Antragstellers dokumentiert.	PP.c oder PP.d	IE.d	IV.d	NP.c

VSR – Übergabe Authentifizierungsmittel

- **Fragen:**
  - Wie wird sichergestellt, dass nur das richtige Subjekt das Authentifizierungsmittel/-faktor erhält?
  - Wie wird verhindert, dass Unberechtigte das Authentifizierungsmittel in ihren Besitz bringen können?
  - Bei Auslieferung per Post:
    - Ist die vom Antragsteller angegebene Post-Adresse gültig?
    - Kann die Postadresse der behaupteten Identität zugeordnet werden?

VSR – Übergabe Authentifizierungsmittel

- **Ausprägungen:**
  - **Stufe 1**: Einfache Auslieferung: «Bestimmte Gewissheit», Post-Adresse selbstdeklariert
  - **Stufe 2**: Sichere Auslieferung: Stufe 1 und
    - Das Authentifizierungsmittel sollte nur das richtige Subjekt erreichen
    - Bei digitaler Auslieferung muss das Authentifizierungsmittel mit einer digitalen Signatur geschützt werden.
  - **Stufe 3**: Persönliche Auslieferung: Stufe 2 und
    - die Existenz und die Zugehörigkeit der Adresse zum Subjekt muss überprüft werden.
    - Adressangaben werden gültigem Beweismittel entnommen.

VSR – Übergabe Authentifizierungsmittel

- **Stufen 4:** Stufe 3 und
  - **Stufe 4a**: Mit Aktivierungs-Prozess für das Authentifizierungsmittel
    - Das Authentifizierungsmittel darf nur das richtige Subjekt erreichen
    - Digitale Auslieferung: ein sicherer Kanal und das Subjekt (oder ein autorisierter Vertreter) muss den Empfang bestätigen.
    - Der Aktivierungsprozess darf nur eine bestimmte Zeit aktiv sein (max.10 min bei digitaler Auslieferung des Aktivierungscodes; max. 7 Tage Post im Inland; max. 21 Tage für Auslandspost).
    - Adressangaben werden gültigem Beweismittel entnommen und geprüft.
  - **Stufe 4b**: Eigenhändige Übergabe
    - Das Authentifizierungsmittel wird dem persönlich physisch anwesenden Subjekt direkt von einer vom CSP autorisierten Stelle übergeben. Die Identität des Subjektes wird durch einen Vergleich körperlicher Merkmale mit einem geeigneten Beweismittel (starke Validierung IV.c) überprüft. Der Empfang wird quittiert.

VSR - Verlängerung/Ersatz Authentifizierungsmittel

- **Fragen:**
  - Unter welchen Bedingungen kann ein noch gültiges Authentifizierungsmittel verlängert bzw. ein revoziertes Authentifizierungsmittel ersetzt werden?
  - Wie kann bei der Verlängerung/Ersatz garantiert werden, dass das Subjekt noch existiert und die gemachten Angaben (z.B. zur Adresse) noch stimmen?

- **Ausprägungen**:
  - **CN1**: Verlängerung nach Vorweis/**Einfacher** Ersatz
    - Das noch gültige Authentifizierungsmittel wird bei der Beantragung der Verlängerung vorgewiesen.
    - Neues Authentifizierungsmittel wird **einfach** ausgeliefert (Übergabe Stufe 1)

VSR - Verlängerung/Ersatz Authentifizierungsmittel

- **CN2**: Verlängerung nach Vorweis/ **Sicherer** Ersatz
  - Verlängerung: Wie CN1
  - Neues Authentifizierungsmittel wird **sicher** ausgeliefert (Übergabe Stufe 2)
- **CN3**: Verlängerung nach Vorweis/ **Persönlicher** Ersatz
  - CN2 + IDN2
  - Neues Authentifizierungsmittel wird **persönlich** ausgeliefert (Übergabe Stufe 3)
- **CN4**: Verlängerung / **Persönliche** Ersetzung
  - CN3 +
  - Es muss ein Beweismittel der Stufe IE.d vorgelegt und die Angaben nach Stufe IV.d validiert werden.
  - Neues Authentifizierungsmittel wird **eigenhändig** übergeben (Übergabe Stufe 4)

Qualität der Authentifizierung

- Überblick
  - Vertrauensstufen der Authentifizierung (VSA)
  - Vertrauensstufen der Registrierung (VSR)
  - Vertrauensstufen der Steuerung (VSS)
  - Vertrauensstufen der Föderierung (VSF)

Vertrauensstufen der Steuerung (VSS)

Vertrauensstufe der Steuerung (VSS)	Aufsicht	Haftung	Maturität
1	Intern nach eigenem Standard oder gar nicht	Keine Haftung	Initial
2	Intern nach vordefinierten Regeln/Standards	Beschränkte Haftung	Definiert
3	Externes Audit	Haftung nach Gesetz	Verwaltet, gemessen
4	Audit durch akkreditierte Stelle	Haftung + Konventio-nalstrafe	Optimiert, integriert

Kriterien der Steuerung

- **Fragen Aufsicht:**
  - Wie vertrauenswürdig sind die Dienstanbieter?
  - Wie gut ist die Prozessqualität der Dienstanbieter?
  - Wie beaufsichtigt sind die Dienstanbieter?
- **Fragen Haftung:**
  - In welchem Umfang haftet der Dienstanbieter?
- **Fragen Maturität:**
  - Wie reif ist das System der Registrierung und Authentifizierung?
  - Wie gut ist der Dienstanbieter in der Lage eigene Erkenntnisse, wie z.B. Sicherheitsvorfälle, zu erheben?
  - Wie gut/schnell ist der Dienstanbieter in der Lage auf Grund von neuen Erkenntnissen (eigene oder externe) seine Prozesse anzupassen?

Qualität der Authentifizierung

- Überblick
  - Vertrauensstufen der Authentifizierung (VSA)
  - Vertrauensstufen der Registrierung (VSR)
  - Vertrauensstufen der Steuerung (VSS)
  - Vertrauensstufen der Föderierung (VSF)

Vertrauensstufen der Föderierung (VSF)

- Nur für föderierte Systeme

Vertrauens-stufen der Föderierung (VSF)	Nachweis des Be-sitzes der Auth. Best.	Authentizität	Vertraulich-keitsschutz	Übermittlungs-form
1	Überbringer	Digitale Signatur	Keiner	Unabhängig
2	Überbringer	Digitale Signatur	Ver-schlüsselung	Front Channel
			Keiner	Back Channel
3	Überprüfbar durch RP	Digitale Signatur	Ver-schlüsselung	Unabhängig

VSF – Kriterium Nachweis Besitz der Authent.bestätigung

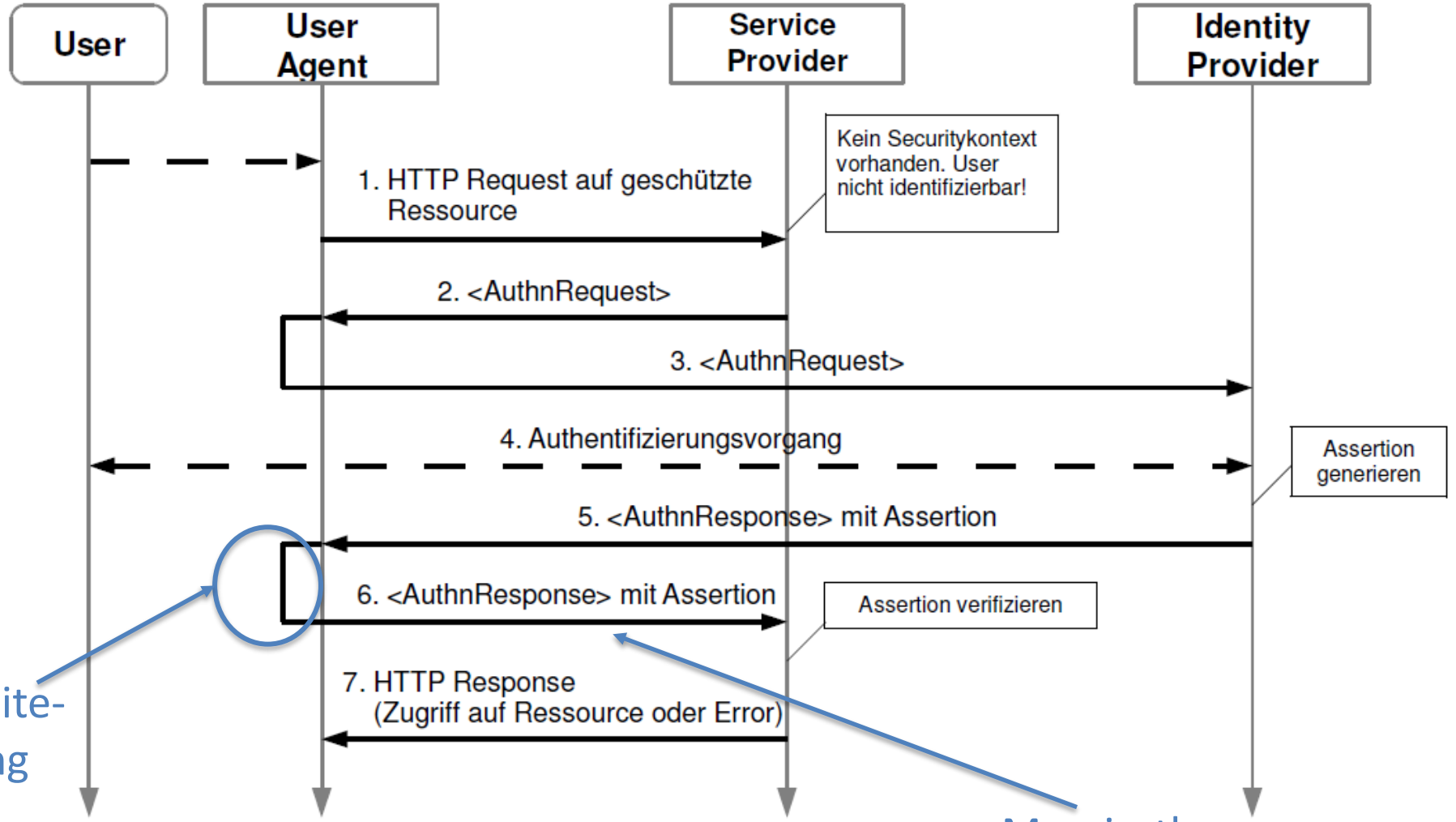
- **Fragen:**
  - Kann die Authentifizierungsbestätigung das Subjekt genügend identifizieren?
  - Repräsentiert die Authentifizierungsbestätigung sicher das referenzierte Subjekt (Abonnent)?
  - Gibt es Schutz gegen Impersonation-Attacken?
  - Ist der Überbringer der Authentifizierungsbestätigung auch das sich zuvor authentifizierte Subjekt)?

- **Ausprägungen:**
  - Überbringer - Bearer (B)
  - Überprüfbar durch RP - Holder-of-Key (HoK)

Holder of Key (SAML HoK Web SSO)

- Kryptographische Bindung der SAML Assertions an den Browser des Benutzers über ein (selbstsigniertes) Clientzertifikat
- Realisierung durch gegenseitige zertifikatsbasierte Authentifizierung während des TLS Handshakes zwischen Browser und Webserver
- Gestohlene Assertions sind für den Angreifer wertlos, da sie nicht den privaten Schlüssel des Clientzertifikats besitzen
- Verhindert: Cross-Site Scripting- und Man-in-Middle-Angriffe

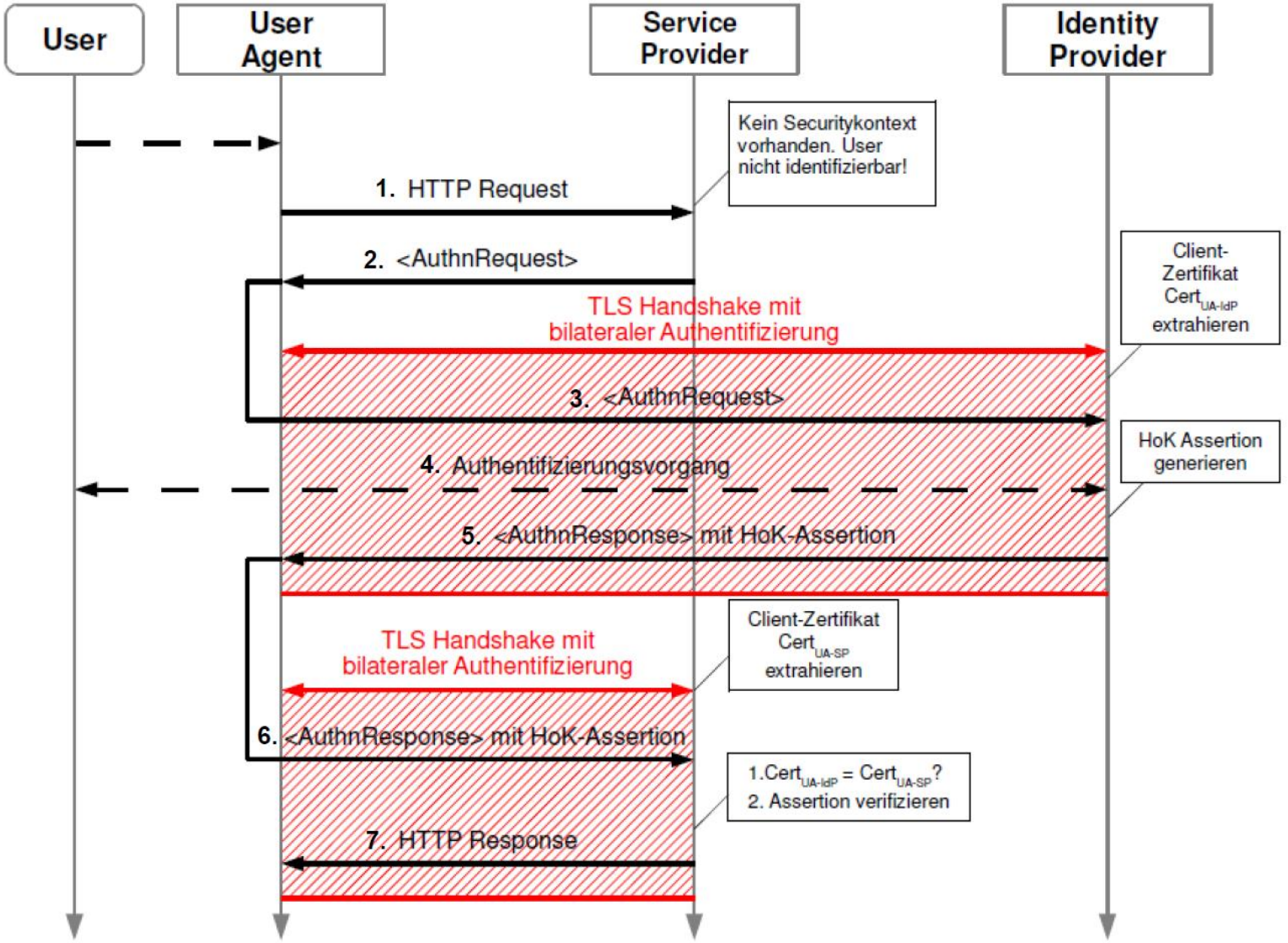
SAML Web SSO



Cross-Site-Scripting

Man-in-the Middle

Holder of Key (SAML HoK Web SSO)



VSF – Kriterium Authentizität der Authent.bestätigung

- **Fragen:**
  - Sind die Herkunft und die Unversehrtheit der Authentifizierungsbestätigung nachweisbar?
  - Ist die Authentifizierungsbestätigung authentisch?
  - Ist der Aussteller eindeutig identifizierbar?
  - Kann der Aussteller abstreiten, die Authentifizierungsbestätigung ausgestellt zu haben?

- **Ausprägungen:**
  - Keine Massnahmen
  - Massnahmen zur Sicherung der Authentizität (Digitale Signatur)

VSF – Kriterium Vertraulichkeitsschutz Authent.bestätigung

- **Fragen:**
  - Ist die Authentifizierungsbestätigung so geschützt, dass unberechtigte Dritte die enthaltenen Informationen nicht einsehen können?

- **Ausprägungen:**
  - Keine Verschlüsselung
  - Verschlüsselung

VSF – Kriterium Übermittlungsform der Authent.bestätigung

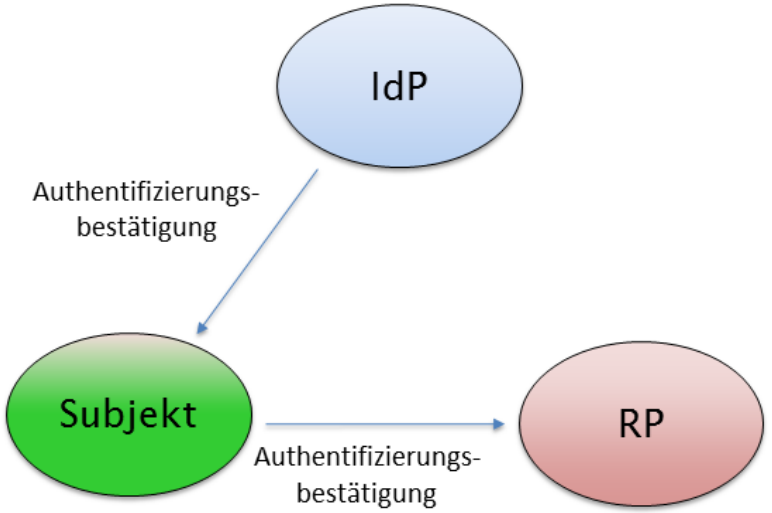
- **Fragen:**
  - Wird die Authentifizierungsbestätigung so übermittelt, dass unberechtigte Dritte die enthaltenen Informationen nicht einsehen können?

- **Ausprägungen:**
  - Front Channel
  - Back Channel

Übermittelungsform

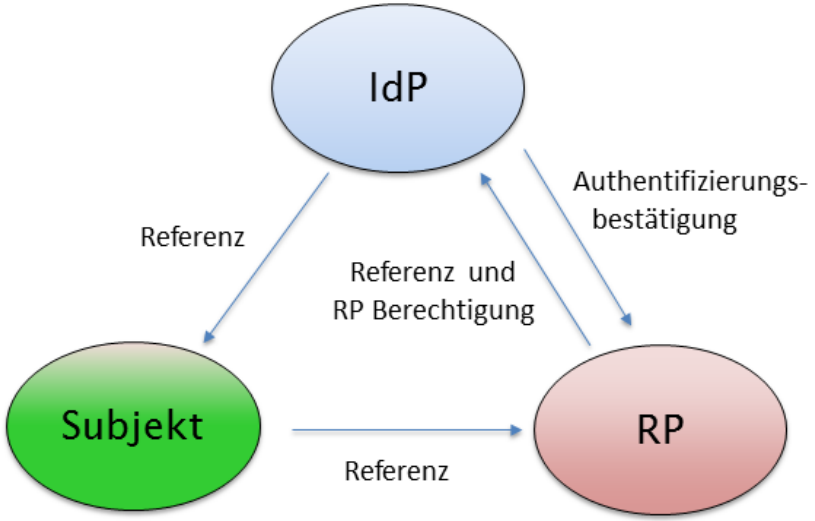
Front Channel

IdP sendet an das Subjekt (bzw. Client Applikation). Das Subjekt übergibt diese der RP.



Back Channel

IdP übergibt eine Referenz (z.B. Redirect URL) an das Subjekt, das dieses an die RP weitergibt. Mit dieser Referenz kann die RP beim IdP innerhalb der erlaubten Zeitspanne und mit entspr. Berechtigung die Authent.bestätigung abholen.



Gesamtmodell – eCH-0170 V2

Vertrauensstufe	Bezeichnung	VSA	VSR	VSS	VSF
1	Kein oder minimales Vertrauen	VSA1 ein Faktor	VSR1 Angaben selbstdeklariert, nicht überprüft	VSS1 Keine Aufsicht, keine Haftung	VSF1 Datenherkunft und –Integrität feststellbar
2	Geringes Vertrauen	VSA2 2FA oder MFA	VSR2 Angaben überprüft, Subjekt ist online	VSS2 Beschränkte Haftung	VSF2 Vertraulichkeits-schutz
3	Beträchtliches Vertrauen	VSA3 HW-MFA	VSR3 Starke Überprüfung	VSS3 Überwachung, Haftung	VSF2 Vertraulichkeits-schutz
4	Hohes Vertrauen	VSA4 Zertif. HW-MFA	VSR4 Staatlich anerkannte Beweismittel, Prüfung biometr. Merkmale	VSS4 Überwachung akkred. Stelle, Haftung & Konventionalstrafen	VSF3 Holder of Key

Qualität der Attribute

- Ein bisher ungelöstes Problem
- (Gescheiterte) Versuche:
  - STORK
  - eCH-0171

Einflussfaktoren auf die Attributqualität

- **Lebensdauer der Attributwerte (2 Kategorien)**
  - Attribute, bei denen sich die Werte selten ändern (z. B. Name, Vorname, Geburtsdatum).
  - Attribute, bei denen die Werte regelmässig geprüft werden müssen (z. B. abgeleitete Attribute wie das Alter des Subjekts, Adresse, Kantonszugehörigkeit).
- **Datenherkunft**

  Die Verwendung der Attribute auf der RP hat einen Einfluss auf die Anforderungen an die Attributbestätigungen. Wenn z. B. die Attribute für Zugangs- und Zugriffsbestätigungen verwendet werden, kann es wichtig sein die **Quelle der Attribute** und deren **Prozesse zur Bestimmung** der Attributwerte zu kennen.
- **Übermittelungsart:** Signatur, Verschlüsselung, Front/Back Channel
- **Qualität der Authentifizierung**
- **…**

Pragmatisches Schema

- **Selbstdeklarierte/unbestätigte Attribute**
  - z.B. Titel (bzw. Anrede)
- **Bestätigte Attribute**
  - Wohnadresse (Wohnadresse des Subjekts, die die Post bestätigt)
  - E-Mail-Adresse / Mobil-Nr.
- **Staatlich bestätigte Attribute**
  - Geburtsdatum

- Frage: Was ist ein staatlich bestätigtes Attribut bei einer Identität der Vertrauensstufe 1 wert?

Wiederholungsfragen / Diskussion

1. Warum sollte man die Qualität der Attribute nicht unabhängig von der Qualität der Authentifizierung betrachten?

2. Warum reicht es nicht, bei der Qualitätsbestimmung nur technische Aspekte zu betrachten?

3. Wie kann man entscheiden, welche Qualitätsstufe man für ein System braucht?

4. Welche Kriterien könnte man noch in ein Qualitätsmodell aufnehmen?